GitHub AI Radar — 2026-10-28

北京时间 2026-10-28 08:00 – 08:07 扫描 GitHub Trending（全语言、Python、TypeScript、Rust、Go）、GitHub 官方 REST 仓库及 Release、项目 README/许可证，并与 2026-10-27 日报、89 个已跟踪项目、历史 snapshots 与 trends 去重比较。本期确认 5 个首次正式收录项目，其中 agentgateway v1.7.0 是 10 月 27 日刚发布的重要兼容性与策略升级，tuios v0.11.1 修复 3 项高危安全问题；AutoSwarm、Auto Ontology 与 Zeron 则分别代表跨 Harness 协作、语义知识层和原生多设备控制面。累计跟踪 94 个项目。

> 量化口径： Stars/Forks 来自 2026-10-28 00:06 – 00:07 UTC GitHub 官方 REST 非原子快照；Trending “ stars today ” 是滚动榜单值，不等于自然日净增。下列版本、功能和风险主要基于官方发布说明与 README，尚未进行独立安装、渗透测试或性能复现。首次收录不等于项目今日创建。

核心判断

Agent 生态的治理边界正从单个 Harness 扩展到网关、终端工作区、跨 Agent 共享状态与企业语义层。 10 月 27 日 agentgateway 的变化最具工程实质：模型能力/成本目录、MCP 工具输出检查、会话密钥与动态后端网络边界同时升级；tuios 的三项高危修复则说明 “ 只读/列表权限 ” “ Git 仓库配置 ” “ 终端输出 ” 都可能成为越权执行入口。相比昨天的 HarnessRouter/Omnigent，本期强调 网关侧可执行策略与实际漏洞修复证据，而不是重复收录通用多 Agent UI。

1. agentgateway v1.7.0：模型路由、MCP Guardrails 与会话加密成为统一控制面

- 官方仓库： https:/ / github.com/ agentgateway/ agentgateway 。GitHub REST 5,683 Stars / 1,003 Forks， Apache-2.0， 2025-03-18 创建；首次纳入 Radar。v1.7.0 于 2026-10-27 17:18 UTC 发布： https:/ / github.com/ agentgateway/ agentgateway/ releases/ tag/ v1.7.0 。
- 模型目录通过 /v1/models 与 CEL 暴露上下文窗口、模态和能力；成本按实际服务层级计量，并可按模型/用户查看 token、成本、缓存命中率与延迟。虚拟模型可调用自定义路由服务。
- 重要安全/兼容性变更： standalone MCP 会话默认使用密钥加密；除 webhook 外的 prompt guard 默认检查 ToolOutput ；mcpGuardrails 支持 CEL 对 MCP 请求/响应实施拒绝或转换；动态后端默认拒绝 loopback/link-local 地址；支持从 Agent 请求头识别会话及 OIDC 浏览器/API 客户端策略。
- 升级注意： 旧会话密钥可能导致客户端重新建会话；默认 ToolOutput 检查可能增加第三方审核 API 传输内容、误拒绝与费用；动态后端限制可能影响本机测试；config.session.key: disabled 和 allowDynamicLoopback: true 是显式放宽选项 ，不能默认建议开启。
- 与昨日对比： HarnessRouter 主要统一执行接口和工具流， Omnigent 侧重跨 Harness 协作及凭据代理；agentgateway 更接近 LLM/MCP 网络入口的身份、策略、审计和计费数据平面。需要实测 CEL 策略绕过、跨副本会话撤销和工具输出的提示注入拦截率。

2. tuios v0.11.1：三项高危漏洞暴露终端 Agent 控制面的权限边界

- 官方仓库： https:/ / github.com/ Gaurav-Gosain/ tuios 。GitHub REST 6,150 Stars / 285 Forks， MIT， 2025-09-06 创建；首次收录。v0.11.1 于 2026-10-26 13:17 UTC 发布： https:/ / github.com/ Gaurav-Gosain/ tuios/ releases/ tag/ v0.11.1 。
- tuios 是具备 Agent 状态感知、跨设备终端会话、worktree 与消息 Inbox 的终端工作区；v0.11.0（10 月 25 日）把多机 Agent 的会话、差异和人工干预整合到 Inbox。
- 官方披露并修复的三项 High 安全公告：

- GHSA-5q2q-f2hv-wf4h：低权限关联设备可通过 stash/screenshot 等路径读取或覆写本机文件，影响 v0.8.0 – v0.11.0。
- GHSA-qcx6-vr32-xr8q：仓库可通过 Git hooks/filter/textconv 让 daemon 在 Agent pane/沙箱外执行程序，影响 v0.8.0 – v0.11.0。
- GHSA-5cvj-c8rj-c749：终端输出可影响提示行并诱导命令执行，影响 tuios v0.7.0 – v0.11.0 和早期 tuios.dev/vt。
- 操作提醒： 官方明确需要升级后执行 tuios restart-server 才会让修复进入 daemon；这里只记录官方建议，未在用户机器上安装或执行。
- 意义： 终端控制面的“ 可见会话 ”“ Git 只读操作 ”不等于安全边界。审计应覆盖跨设备能力、daemon Git 子进程和终端文本/键盘输入的信任隔离；这是比 Stars 更有证据价值的入选理由。

3. HKUDS AutoSwarm：共享上下文与能力路由的跨 Agent 协作层

- 官方仓库： https:/ / github.com/ HKUDS/ AutoSwarm 。GitHub REST 2,033 Stars / 368 Forks，MIT，2026-07-01 创建；本次首次收录，没有已核验的 GitHub Release。10 月 28 日 Python Trending 滚动榜约 33 stars today，不是新项目当天爆发的证据。
- 官方 README 描述通过轻量 Skill/运行时调用 Codex、Claude Code、OpenCode、Cursor、DeepSeek Harness 等，按能力选择 Agent，协调工具与任务并共享上下文/记忆；提供 autoswarm doctor 的环境探测与配置恢复流程。项目文档包含协调算法说明。
- 与昨日对比： Omnigent/HarnessRouter 偏策略网关和统一执行接口；AutoSwarm 更强调 能力选择、共享任务上下文与协作编排。三者互有交集，不能将 README 支持列表视为全部 Harness 已通过独立兼容性测试。
- 验证边界： 重点测试任务重复执行、跨 Agent 状态污染、共享记忆隔离、权限继承和失败后恢复。不要在未经检查的环境里让安装 Skill 自动接管本地凭据。

4. NVIDIA Auto Ontology：把企业语义知识图谱作为可授权的 Agent 上下文层

- 官方仓库： https:/ / github.com/ NVIDIA/ auto-ontology 。GitHub REST 340 Stars / 44 Forks，Apache-2.0，2026-04-27 创建；首次收录，未核验到正式 GitHub Release。10 月 28 日 Python Trending 滚动榜显示约 80 stars today；不是新发布或独立性能证据。
- 官方 README 定义 Discover（从元数据构建/连接本体）、Ground（统一指标、实体、关系语义）、Expose（通过 MCP、CLI、API 提供上下文）三个阶段；包含企业连接、认证/RBAC、面向 NL-to-SQL 的模型角色、会话按用户隔离和 MCP 入口。
- 与既有 Radar 对比： Graphify/Graphicle 聚焦代码图谱与文件级证据；Auto Ontology 面向 业务语义一致性、指标定义与结构化数据检索，是 RAG 从向量召回向可治理语义层发展的另一条路线。
- 验证边界： 本体自动生成的实体链接、指标口径、跨数据源联结正确率、授权与租户隔离都需独立测试；项目 README 的 benchmark 不应直接等同生产环境精度。

5. Zeron v0.2.127：原生多 Harness 客户端的子 Agent 可见性与远端信任模型

- 官方仓库： https:/ / github.com/ zeronsh/ zeron 。GitHub REST 3,402 Stars / 350 Forks，MIT，2026-07-20 创建；首次收录。v0.2.127 于 2026-10-27 18:58 UTC 发布： https:/ / github.com/ zeronsh/ zeron/ releases/ tag/ v0.2.127 。
- Zeron 提供本机优先的 Claude Code/Codex/Cursor 等 Harness 桌面控制面、Linux headless daemon、可选跨设备同步。新版加强 Claude 前台子 Agent 的文本/推理状态呈现、会话 fork 与子 Agent 对应关系、图片展示，以及远端会话同步状态；云端引入每账户活跃机器/聊天配额。
- 关键权限提示： README 明确：启用同一账号跨设备同步后，登录设备可读写彼此工作区文件；不应把“ 默认本地 ”理解为启用同步后仍天然隔离。既有本机会话不会自动上传是项目声明，尚未独立验证。

- 与昨日对比：ThinkRail 以 IDE/worktree/SPEC.md 为主，Zeron 以多 Harness 原生客户端、headless daemon 和远端会话控制为主。新版属于增量功能与状态可靠性更新，不应写成新型沙箱或重大发明。

去重、许可证核查与观察清单

- superdesigndev/treg（https:/ / github.com/ superdesigndev/ treg，6,389 Stars）提出“ OpenRouter for tools ”的统一代理/凭据注入架构，但 LICENSE 在 Apache-2.0 基础上禁止未经许可向第三方提供托管/嵌入服务，不满足 OSI 开源定义；只作 source-available 观察，不加入开源跟踪数据库。
- multica-ai/multica（https:/ / github.com/ multica-ai/ multica，54,010 Stars）v0.7.1 于 10 月 27 日发布，增加 Devin CLI/ACP、Workflow 等，但官方 README 自称 source-available，LICENSE 对第三方托管/嵌入设置限制；不按 OSI 开源项目收录。
- fabio-rovai/open-ontologies（https:/ / github.com/ fabio-rovai/ open-ontologies，1,802 Stars）v2.1.0 于 10 月 23 日修复 SHACL/enforce 等在判定失败时仍退出 0 的问题；值得继续观察自动验证的 fail-closed 语义，但本期优先记录更新更近、边界更明确的 5 个项目。
- elayadesign/ai-design-skills 进入全语言 Trending（滚动约 1,395 stars today），但与 10 月 26 日 Hallmark/Impeccable 的前端 Skill 主题高度重合，缺少本次独立架构突破；不机械重复收录。
- nightly-labs/openbot 再次进入 Trending，但此前已核验 PolyForm Noncommercial 限制，不列为 OSI 开源项目。其他已报道项目 Hallmark、Impeccable、Cindy、ThinkRail、SkillSpector 等继续活跃，未因单纯榜单排名重复发布。

下一步验证优先级

优先建立三类可重复测试：(1) 对 agentgateway 的 ToolOutput/MCP CEL 拒绝、SSRF 保护、会话重建和隐私外传进行策略回归；(2) 对 tuios 三个 GHSA 的修复版本进行授权与沙箱逃逸回归；(3) 对 AutoSwarm/Zeron 的跨 Agent 状态与跨设备文件授权，以及 Auto Ontology 的语义/租户隔离做受控对照。当前记录均为官方一手材料核验，非独立复现结论。

同日量化与 Release 证据索引：data/snapshots/2026/10/2026-10-28.json。